

SECURITY INCIDENT REPORT: Zenith Technologies Breach

Name: Chigozie David Okechukwu

Course: Cybersecurity

Date: April 10, 2026

Subject: Analysis of Remote Code Execution and Ransomware Incident

Introduction

The scenario highlights a classic tension between operational stability and security urgency. This report analyzes the exploitation of an unpatched Windows vulnerability and provides remediation strategies.

1.1 Attack Identification and Timeline

Type of attack: This was a Ransomware attack performed through Remote Code Execution (**RCE**) exploit. The attacker utilized a critical windows vulnerability to gain unauthorized access to the network without needing user interaction and eventually encrypting all files and demanding payment.

Vulnerability Factor

Zenith Technologies remained vulnerable due to a failure to apply an emergency security patch. Any machine connected to the internet without this patch served as an open gateway for external exploitation.

1.2 Attacker Timeline (Monday-Tuesday)

Monday(Reconnaissance): As soon as Microsoft released the bulletin attackers used automated scanners (like shodan and custom script) to find IP addresses in Lagos still running with the unpatched windows system.

Tuesday(Exploitation and Lateral Movement): Once a foothold was gained on the three finance computers, the attackers moved laterally through the network. They likely spent this time identifying sensitive customer databases and exfiltrating (stealing) data to an external server.

Wednesday (Impact): After stealing the data, the attacker deployed the ransomware payload to lock the transaction systems and display the ransom note to maximize leverage for payment.

1.3 Evaluation of IT Management Decision

Assessment: The IT manager's decision was incorrect. While compatibility testing is important, a two-week delay for a critical RCE vulnerability in a high-stakes fintech environment represents an unacceptable level of risk.

Recommended Action: Instead of a total delay, the manager should have implemented an **Emergency Change Window**:

1. Pilot Testing: Deploy the patch to a small "test group" of computers running the banking software. This can often be completed in a few hours.

2. Compensating Controls: If testing failed, the manager should have isolated the vulnerable finance computers from the internet or placed them behind a strict VPN/Firewall block until a solution was found.

Failed Best Practice: The manager failed to follow Risk-Based Patching. This practice requires weighing the likelihood and impact of an exploit against the potential for software instability. In this case, the risk of a total business shutdown far outweighed the risk of a temporary banking software glitch.

1.4 Microsoft Patch Classification

Patch Type: Microsoft released an **Out-of-Band (OOB) Patch**. These are emergency updates released outside of the standard monthly "Patch Tuesday" cycle.

Why It Must Not Be Delayed:

Public Exposure: Once a patch is released, the vulnerability is no longer secret. Attackers reverse-engineer the patch to figure out exactly how to break the software. This creates a race between the IT team and the hacker.

Criticality: OOB patches are reserved for vulnerabilities that are currently being exploited in the wild or have the potential for massive, automated spread (like a worm). Delaying these patches is equivalent to leaving a bank vault open after announcing the lock is broken.

1.5 Remediation

1. Immediate Eradication (Stopping the Bleeding)

Isolation

Disconnect the three compromised finance computers and the affected transaction server from the network immediately. This prevents the

ransomware from spreading further or communicating with the attacker's server.

Patching (The Original Issue)

Deploy the **Out-of-Band (OOB) patch** across all 200 workstations immediately. The risk of banking software incompatibility is now irrelevant compared to the active breach.

Password Reset

Force a company-wide password reset. Attackers often steal credentials during a buffer overflow to ensure they can get back in even after the hole is patched.

2. Recovery and Restoration

Backup Restoration

Instead of paying the ransom, Zenith should wipe the infected systems and restore data from the most recent offline backups.

Backups must be scanned for malware *before* restoration to ensure the attacker didn't hide malware in them.

System Integrity Check

Verify that the core banking software is still functioning correctly after the patch. If glitches occur, IT should work with the software vendor for a hotfix rather than uninstalling the security patch.

3. Long-term Strategic Remediation

To ensure this never happens again, the IT manager must move from a reactive to a proactive security posture.

Implement a Tiered Patch Management Policy

Zenith should adopt a **Deployment Ring** strategy. Instead of waiting two weeks for everyone, they should:

Ring 0 (Immediate): Patch a small group of non-critical test machines.

Ring 1 (24 Hours): Patch 10% of the company, including one banking machine.

Ring 2 (48 Hours): Full production rollout.

Network Segmentation

The finance department and transaction systems should be on a separate VLAN from general office computers. This ensures that even if a regular employee's PC is compromised via a buffer overflow, the attacker cannot easily "reach" the sensitive financial data.

Implement Compensating Controls

Since some software (like the banking app) is sensitive to updates, Zenith should use:

IPS (Intrusion Prevention System): To detect and block the specific network "patterns" used in buffer overflow attacks.

EDR (Endpoint Detection and Response): To alert the SOC team the moment a process starts behaving strangely in memory.

Summary

The Attack: Attackers used a **Buffer Overflow** to execute malicious code into the computer's memory. This gave them a remote control, which they used to steal data and deploy Ransomware.

The Mistake: The IT Manager delayed an **Out-of-Band (emergency) patch** for two weeks. He worried about software glitches but ignored the certain risk of being hacked once the vulnerability was made public.

The Lesson: In security, speed is a defense. He should have tested the patch on one or two computers for a few hours (**Pilot Testing**) instead of leaving the whole company exposed for weeks.

Remediation: Isolate infected PCs, restore from backups, and patch everything immediately.